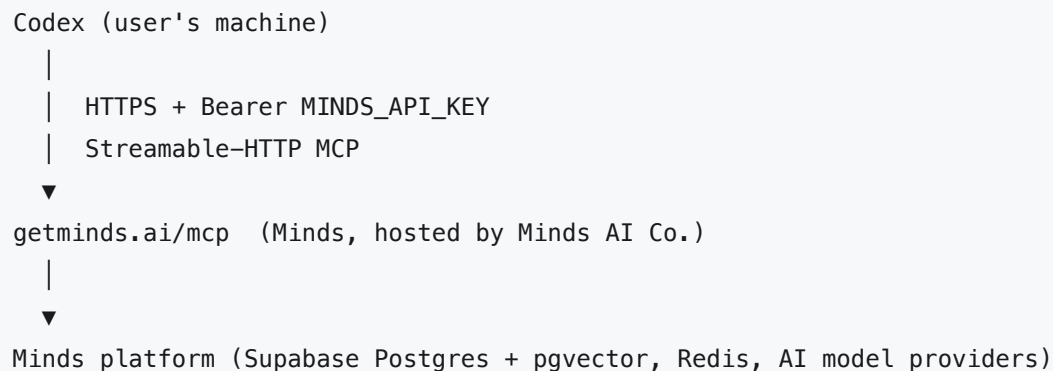


Minds Codex Plugin — Security & Privacy

For the OpenAI Codex Plugin Directory review. Last updated 2026-07-16.

Architecture



No code from this plugin executes locally beyond the manifest + skill markdown. No background processes, no telemetry, no auto-update, no shell scripts.

Authentication

- **Auth mechanism.** Personal API key (`minds_...` prefix), 64-char base62 secret.
- **Issuance.** Generated in-webapp via authenticated session. Plaintext shown ONCE at creation.
- **Storage on user's machine.** Codex stores `MINDS_API_KEY` in its built-in secret store (`policy.authentication: ON_INSTALL` , `secret: true`). The plugin never reads or persists the key — Codex injects it into MCP request headers.
- **Scope.** Keys are scoped to one Minds account and inherit that account's existing entitlements.
- **Revocation.** User can revoke at <https://getminds.ai/?settings=api-keys&type=personal>. Effect is immediate.
- **Rotation.** Keys do not auto-rotate. Recommended rotation cadence: 90 days.

Data handling

- **What leaves the user's machine.** Tool arguments (question text, persona names, keywords) over TLS 1.3 to `getminds.ai`.
- **What comes back.** Synthesized persona answers, panel results, status payloads. All JSON, no executable content.
- **Persistence.** Questions, answers, and created Minds are persisted on the user's Minds account (per the user's own retention settings).

- **Training.** Minds does not train its models on user-submitted content. Our model providers (OpenAI, Anthropic, Google) operate under their respective API-tier data-use terms with training opt-out enabled.
- **PII.** Users can submit PII as part of persona context. Standard Minds data-handling policies apply: <https://getminds.ai/privacy>.
- **Sub-processors.** Listed at <https://getminds.ai/subprocessors>.

Widget delivery (Response Widget)

- **Vendor code inlined.** The inline Response Widget (`ui://widget/response.html`) is served from `getminds.ai/mcp` with all JavaScript/vendor libraries inlined — no external `<script>` or ES-module bundles are loaded into the host's sandboxed iframe (verified live 2026-07-16), keeping the host CSP surface minimal.
- **One third-party network call, disclosed.** The bundled icon library (Iconify) may make runtime requests to a public icon API (`api.iconify.design`) to fetch icon glyphs. This is the one third-party origin the widget can reach; it carries **no user or account data** (icon names only) and fails soft (a missing icon simply doesn't render). Bundling icons to remove this last external call is tracked as a webapp hardening item.
- **Data path unchanged.** Apart from that icon fetch, the widget renders only the tool result already returned over the authenticated MCP channel; it introduces no additional data endpoints.

Content moderation

- **Inbound.** Tool arguments pass through Minds' standard prompt-safety layer. Disallowed content (CSAM, weapons synthesis, etc.) is rejected at the gateway.
- **Outbound.** Persona answers are generated through provider models with their default safety filters; additional Minds-side moderation runs before responses leave `/mcp`.
- **Persona consent.** Minds of real, named individuals can only be created by accounts that have accepted Minds' Persona Consent Policy. See <https://getminds.ai/persona-consent>.

Rate limits and reliability

- **Per-account default limits.** 60 requests/minute on `/mcp`, 1000 requests/day across all endpoints. Higher limits available on paid tiers.
- **Endpoint SLA.** 99.5% monthly uptime target. Status page: <https://status.getminds.ai>.
- **Server-side timeout.** 60s per tool call. Background-job tools (`query_panel`, `ask_panel`) return immediately and surface results through polling endpoints.

Vulnerability disclosure

- **Contact.** security@getminds.ai

- **PGP.** <https://getminds.ai/security.txt>
- **Bounty.** Private bug-bounty program; details on request.
- **Disclosure timeline.** Acknowledge $\leq 48h$, triage $\leq 7d$, fix $\leq 90d$ for high/critical.

Compliance posture

- **SOC2 Type 1** — in progress, target completion Q3 2026.
- **GDPR** — DPA available at <https://getminds.ai/dpa>.
- **CCPA** — supported via the privacy policy.
- **Data residency** — primary region US-East. EU residency available on enterprise tier.

Plugin-specific risks and mitigations

Risk	Mitigation
User pastes their <code>minds_...</code> key into the wrong shell history	Codex stores via secret store, never echoes; plugin docs explicitly say "shown ONCE in webapp, paste into Codex prompt"
Plugin updates introduce malicious skill prompts	Plugin is MIT OSS; updates land via GitHub PR review; tagged releases are pinned via marketplace <code>ref</code> field
MCP endpoint compromise leaks user prompts	TLS 1.3 enforced; mTLS available for enterprise; webapp WAF rules log + rate-limit anomalous traffic
Persona-cloning of real individuals without consent	Persona Consent Policy enforced at create time on the Minds backend, not the plugin

What this plugin does NOT do

- Does NOT execute code on the user's machine beyond the static manifest and skill markdown
- Does NOT read files outside its own plugin directory
- Does NOT send any telemetry (no usage pings, no install pings, no error reports)
- Does NOT auto-update (user-initiated `codex plugin marketplace upgrade` only)
- Does NOT call any endpoint other than `getminds.ai/mcp`